

Modulo 09

Analisi di rischi e vulnerabilità di un sistema basato su AI

UrbanSight - piattaforma di visione artificiale per il monitoraggio urbano: valutazione dei rischi, contromisure CIA, conformità GDPR / AI Act / NIS 2 e incident report simulato

Sicurezza delle Informazioni e delle Architetture

Simone La Porta

Master AI Solutions Architect - ProfessionAI

Indice

1. Executive summary	3
2. Contesto, obiettivi e ambito	3
2.1 Il caso d'uso e la posta in gioco	3
2.2 Obiettivi del documento	3
2.3 Ambito ed esclusioni	3
3. Mappatura dell'ecosistema	4
3.1 Asset critici	4
3.2 Flussi e confini di fiducia	5
4. Metodologia di valutazione	5
4.1 Criteri di probabilità e impatto	6
5. Analisi dei rischi e delle vulnerabilità	6
6. Registro dei rischi	9
7. Contromisure ad alto livello (triade CIA)	11
7.1 Confidentiality (riservatezza)	11
7.2 Integrity (integrità)	11
7.3 Availability (disponibilità)	11
7.4 Matrice di tracciabilità rischi-contromisure	12
8. Analisi di conformità normativa	13
8.1 GDPR (Reg. UE 2016/679)	13
8.2 AI Act (Reg. UE 2024/1689)	14
8.3 NIS 2 (Dir. UE 2022/2555, D.lgs. 138/2024)	15
9. Incident report simulato (INC-2026-004)	16
9.1 Sintesi per la direzione	16
9.2 Classificazione e portata	17
9.3 Cronologia	17
9.4 Notifiche e comunicazioni	18
9.5 Causa radice e lezioni	18
10. Raccomandazioni organizzative e roadmap	19
11. Limiti dell'analisi e follow-up	19
Appendice A - Template del registro dei rischi	20
Appendice B - Modello di incident report	20

1. Executive summary

UrbanSight fornisce ai comuni una piattaforma di visione artificiale per il monitoraggio urbano: analisi del flusso veicolare, riconoscimento di situazioni di pericolo, rilevazione di comportamenti pedonali a rischio, gestione adattiva dei semafori e dashboard di pianificazione. Questo documento ne analizza la sicurezza a livello concettuale: mappa l'ecosistema, valuta dieci rischi con criteri qualitativi, propone contromisure organizzative allineate alla triade CIA, verifica la conformità a GDPR, AI Act e NIS 2 e chiude con un incident report simulato che mette alla prova i processi descritti.

Quattro conclusioni guidano la lettura. Primo: il rischio prioritario non è un attacco AI sofisticato ma l'esfiltrazione di dati personali dal footage (R04), che combina probabilità e impatto più alti attraverso vie di attacco del tutto tradizionali. Secondo: subito sotto sta il cluster che minaccia l'integrità del modello (poisoning R01, adversarial R02, supply chain R07), dove il danno è silente e tocca la sicurezza stradale. Terzo: il sistema ricade nella classe high-risk dell'AI Act come componente di sicurezza della gestione del traffico, con obblighi che diventano applicabili ad agosto 2026: la finestra per colmare i gap documentali e di logging è di settimane, non di anni. Quarto: i tre regimi normativi convergono sugli stessi controlli organizzativi (tracciabilità, gestione fornitori, incident response), quindi un unico impianto di governance ben disegnato serve tre conformità insieme.

Per l'azienda la sicurezza di questa piattaforma non è un costo accessorio: è un requisito di incolumità pubblica, la condizione di accesso ai contratti con gli enti locali e l'argomento con cui difendere la fiducia di comuni, cittadini e assicurazioni quando qualcosa andrà storto. L'incident report del capitolo 9 mostra che la differenza tra un incidente gestito e una crisi sta nei processi preparati prima dell'evento.

2. Contesto, obiettivi e ambito

2.1 Il caso d'uso e la posta in gioco

La piattaforma osserva spazi pubblici in tempo reale e agisce su un'infrastruttura critica urbana, la rete semaforica. Questo la distingue da un ordinario prodotto SaaS di computer vision: un errore di classificazione può contribuire a un danno fisico, un archivio video compromesso è una violazione di riservatezza su larga scala, un'interruzione del servizio degrada la gestione della viabilità. I tre assi della triade CIA hanno qui interpretazioni concrete e non intercambiabili, e per questo strutturano le contromisure del capitolo 7.

2.2 Obiettivi del documento

- Mappare l'ecosistema AI a livello concettuale: componenti, dati, flussi, terze parti.
- Identificare e classificare i rischi rilevanti per la visione artificiale urbana.
- Stimare probabilità e impatto con criteri qualitativi espliciti e motivati.
- Proporre contromisure ad alto livello organizzate sulla triade CIA.
- Verificare i requisiti di conformità GDPR, AI Act e NIS 2 con gap analysis.
- Redigere un incident report simulato con timeline, impatti e comunicazioni.
- Fornire raccomandazioni organizzative, di governance e di processo.

2.3 Ambito ed esclusioni

L'analisi copre telecamere e sensoristica, pipeline dati (acquisizione, memorizzazione, training), modelli AI in addestramento e inference, interfacce operative (dashboard, API) e integrazioni con i sistemi di controllo urbano. Restano fuori, per scelta della traccia e coerenza con la natura del documento:

implementazioni tecniche di contromisure, penetration test o exploit attivi, istruzioni operative di attacco. Le minacce sono descritte al livello di dettaglio necessario a valutarle e governarle, non a riprodurle.

Fonti e inquadramento metodologico

L'analisi usa i contenuti del modulo come base (triade CIA, attacchi al ciclo di vita ML, protezione degli asset critici, NIS 2, forensics) e li ancora a riferimenti pubblici: le tassonomie MITRE ATLAS e OWASP Machine Learning Security Top 10 per le minacce AI-specifiche, i testi normativi per il capitolo di conformità. I riferimenti alle tecniche sono per nome, senza numerazione di versione: le tassonomie evolvono e il documento deve invecchiare bene.

3. Mappatura dell'ecosistema

Prima di valutare i rischi serve l'inventario di ciò che si protegge: componenti, flussi di dati, dipendenze esterne e confini di fiducia.

La figura 1 organizza l'ecosistema in tre zone di fiducia. La zona campo raccoglie telecamere, sensori e unità edge distribuite sulla città; la piattaforma cloud concentra storage del footage, pipeline di training e labeling, model registry, inference in tempo reale e interfacce; la zona enti comprende la centrale semaforica, le dashboard comunali e gli operatori. Le terze parti attraversano i confini: vendor di labeling, cloud provider, fornitore di manutenzione con accesso VPN, modelli pre-addestrati.

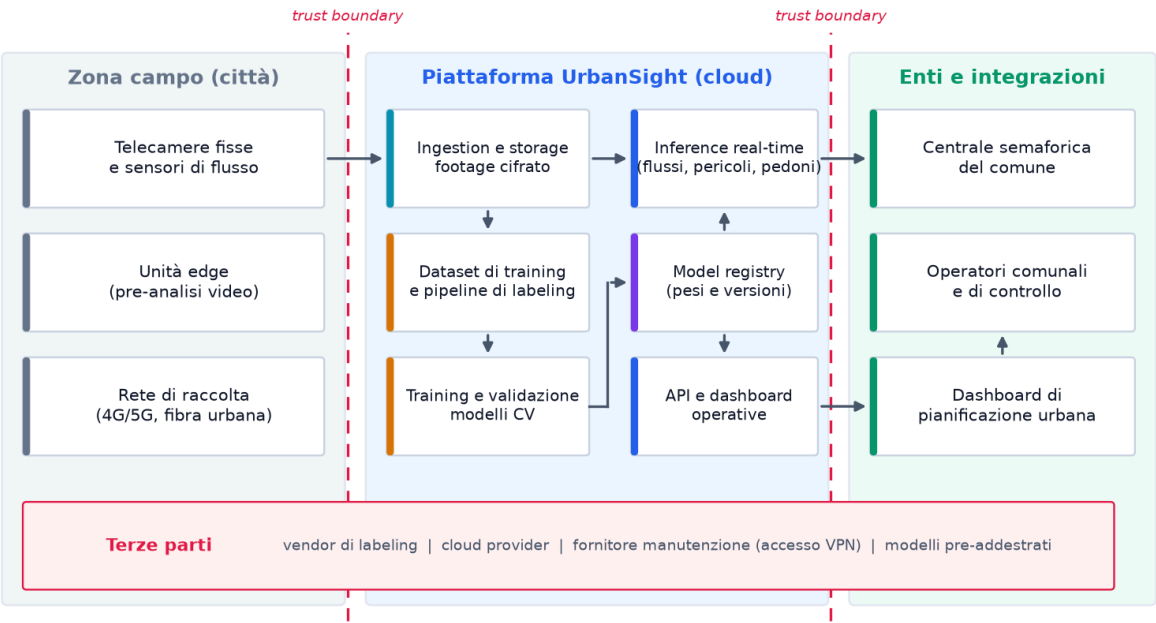


Figura 1 - Ecosistema UrbanSight: zone di fiducia, componenti, flussi principali e terze parti.

3.1 Asset critici

Asset	Descrizione	Dimensione CIA prevalente	Esposizione
Footage e metadati	Registrazioni video e dati derivati, riconducibili a persone	Riservatezza	Storage cloud, accessi interni e di terze parti

Asset	Descrizione	Dimensione CIA prevalente	Esposizione
Dataset di training	Immagini annotate che determinano il comportamento dei modelli	Integrità	Pipeline interna e filiera di labeling esterna
Modelli (pesi e versioni)	Proprietà intellettuale; il loro comportamento è il prodotto	Integrità / Riservatezza	Model registry, API di inference
Servizio di inference	Detection in tempo reale che alimenta allarmi e semafori	Disponibilità / Integrità	Endpoint esposti, dipendenza dal cloud
Interfacce operative	Dashboard e API per comuni e operatori	Riservatezza / Integrità	Utenti esterni, autenticazione
Integrazione semaforica	Canale di attuazione verso l'infrastruttura urbana	Disponibilità / Integrità	Interfaccia con sistemi del comune

Tabella 1 - Asset critici e loro esposizione.

3.2 Flussi e confini di fiducia

Due flussi meritano attenzione particolare. Il primo è il percorso del dato personale: dalla telecamera allo storage, dallo storage al dataset di training, con un'uscita verso il vendor di labeling; ogni attraversamento di confine è un punto in cui la minimizzazione e la contrattualistica devono lavorare insieme. Il secondo è il percorso della decisione: inference, allarme, attuazione semaforica; è il flusso a più alto impatto safety e quello che l'obbligo di tracciabilità deve coprire da capo a fondo.

Lettura critica. La mappatura ridimensiona un'intuizione comune: la superficie d'attacco della piattaforma non è dominata dal modello ma dai punti di contatto con l'esterno, ovvero terze parti con accessi privilegiati, interfacce esposte, filiera di annotazione. Dei dieci rischi del capitolo 5, sette passano da un confine di fiducia con terzi. La conseguenza progettuale è che i controlli organizzativi su accessi e fornitori proteggono più superficie per unità di sforzo di qualunque irrobustimento del modello.

4. Metodologia di valutazione

La valutazione segue il ciclo classico dell'analisi del rischio: identificazione a partire dal catalogo della traccia, analisi di probabilità e impatto, prioritizzazione su una matrice, trattamento tramite le contromisure del capitolo 7. Le minacce AI-specifiche sono ancorate alle tassonomie MITRE ATLAS e OWASP Machine Learning Security Top 10; quelle tradizionali al lessico consolidato della sicurezza informatica. Ho scartato STRIDE come griglia principale: è pensata per la modellazione di sistemi software generici, mentre qui il catalogo dei rischi è già dato e l'esigenza è valutarlo, non rigenerarlo.

4.1 Criteri di probabilità e impatto

Livello	Probabilità (criteri qualitativi)	Impatto (criteri qualitativi)
Bassa / Basso	Richiede accessi o competenze rare; nessun precedente di settore rilevante	Disagio operativo contenuto, nessun danno a persone o dati personali
Media / Medio	Tecnica documentata in letteratura o incidenti di settore noti; richiede capacità non banali	Danno economico o reputazionale significativo, degrado del servizio, esposizione legale limitata
Alta / Alto	Superficie ampia e tecnica accessibile, oppure condizione quasi certa in assenza di intervento	Danno a persone, violazione di dati su larga scala, sanzioni rilevanti o perdita di contratti chiave

Tabella 2 - Ancore qualitative della scala di valutazione.

La priorità combina i due assi secondo la matrice del capitolo 6: critica (alta, alto), alta per le combinazioni con un asse alto e l'altro almeno medio, a scendere fino ad accettabile. La scala a tre livelli è quella richiesta dalla traccia e la ritengo adeguata allo scopo: una granularità 5x5 avrebbe suggerito una precisione che i dati disponibili non sostengono.

Limiti dichiarati dell'approccio qualitativo

Le stime di probabilità non poggiano su serie storiche di frequenza ma su giudizio informato: letteratura, incidenti di settore, caratteristiche della superficie d'attacco. È un limite accettato consapevolmente: l'obiettivo del registro è ordinare gli investimenti di controllo, non quantificare perdite attese. Un approccio quantitativo (per esempio FAIR) richiederebbe dati di perdita che in fase di analisi concettuale non esistono; diventerebbe sensato dopo uno o due anni di esercizio del registro e degli incidenti reali.

5. Analisi dei rischi e delle vulnerabilità

Dieci rischi dal catalogo della traccia, ciascuno collocato sul ciclo di vita del sistema, motivato nella stima e agganciato alle contromisure del capitolo 7.

Ciclo di vita del sistema e superficie di attacco

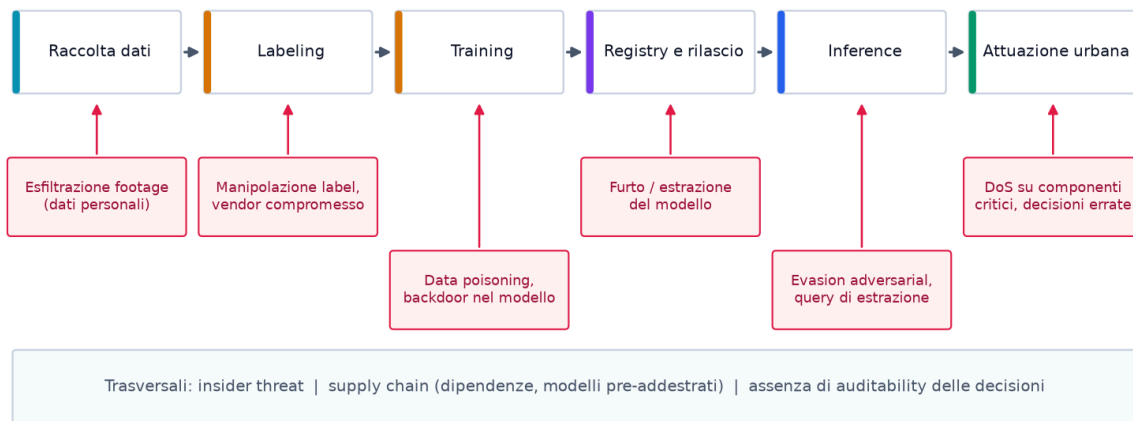


Figura 2 - Le minacce posizionate sul ciclo di vita: dalla raccolta dati all'attuazione urbana, con i rischi trasversali in basso.

R01 - Data poisoning del training set

Inserimento deliberato di esempi malevoli nel dataset di addestramento, tramite accesso alla pipeline interna o attraverso la filiera di labeling. Nel contesto UrbanSight lo scenario più pericoloso non è il degrado generalizzato, che il monitoraggio delle metriche intercetta, ma la backdoor: un trigger fisico ripetibile (un pattern su un cartello, un adesivo) che forza la classificazione scelta dall'attaccante, ad esempio la soppressione sistematica di un allarme pericolo.

Riferimenti: ATLAS: Poison Training Data | OWASP ML: Data Poisoning Attack.

Valutazione: probabilità media, impatto alto, priorità alta. Probabilità media: serve accesso alla pipeline dati o al vendor di labeling, quindi l'attacco non è alla portata di chiunque, ma la filiera esterna amplia il perimetro. Impatto alto: il comportamento corrotto è silente, persiste tra i rilasci e tocca decisioni di sicurezza stradale. Contromisure collegate: I1, I2, I4, I6.

R02 - Attacchi adversarial in inference

Input manipolati a tempo di inference per indurre errori di classificazione: perturbazioni digitali sul flusso video o, più realistico in ambito urbano, pattern adversarial fisici (patch, sticker) collocati nella scena. Effetti possibili: occultare un pedone o un incidente alla detection, oppure generare falsi allarmi in quantità tale da degradare la fiducia degli operatori nel sistema.

Riferimenti: ATLAS: Craft Adversarial Data, Evade ML Model | OWASP ML: Input Manipulation.

Valutazione: probabilità media, impatto alto, priorità alta. Probabilità media: la letteratura sugli attacchi fisici è matura e le telecamere sono in spazio pubblico, ma servono competenze specifiche e prove sul campo. Impatto alto: un mancato riconoscimento di pericolo agisce direttamente sulla catena safety (semafori, allarmi). Contromisure collegate: I3, I6, A3.

R03 - Furto ed estrazione del modello

Esfiltrazione diretta dei pesi dal model registry tramite accessi non autorizzati, oppure replica funzionale del modello con query sistematiche alle API di inference. Oltre al danno di proprietà intellettuale, un modello rubato abilita la preparazione white-box degli attacchi adversarial di R02, che diventano più precisi ed economici.

Riferimenti: ATLAS: Exfiltration via ML Inference API | OWASP ML: Model Theft.

Valutazione: probabilità media, impatto medio, priorità media. Probabilità media: il registry è un bersaglio definito e gli accessi di terze parti ne allargano l'esposizione. Impatto medio: il danno immediato è economico e competitivo; quello su safety è indiretto, mediato da R02. Contromisure collegate: C2, C3, I6.

R04 - Esfiltrazione di dati personali

Sottrazione di footage e metadati riconducibili a individui: volti, targhe, abitudini di spostamento. Le vie di attacco sono in gran parte tradizionali: compromissione di credenziali, accessi di terze parti, storage cloud configurato male, dashboard esposte. È il rischio che l'incidente simulato del capitolo 9 mette alla prova.

Riferimenti: Minaccia classica (esfiltrazione) su asset AI | GDPR artt. 33-34.

Valutazione: probabilità alta, impatto alto, priorità critica. Probabilità alta: l'asset è appetibile, la superficie è ampia e gli incidenti di settore su archivi di videosorveglianza sono ricorrenti. Impatto alto: violazione di riservatezza su larga scala, obblighi di notifica, sanzioni e perdita di fiducia dei comuni clienti in un colpo solo. Contromisure collegate: C1, C2, C3, C4, I6.

R05 - Compromissione della pipeline di labeling

Errore sistematico o manipolazione delle etichette prodotte dal vendor esterno di annotazione. Condivide il canale con R01 ma non l'intenzionalità: qui il caso tipico è il bias sistematico o il calo di qualità non rilevato, che degrada il modello in modo diffuso invece che mirato.

Riferimenti: ATLAS: Poison Training Data (via supply chain di annotazione).

Valutazione: probabilità media, impatto medio, priorità media. Probabilità media: la filiera è esterna e il controllo di qualità sulle annotazioni è oggi limitato. Impatto medio: il degrado è osservabile dalle metriche più di quanto lo sia una backdoor, e la correzione è costosa ma non un'emergenza safety immediata. Contromisure collegate: I2, I4, C3.

R06 - Insider threat

Accessi o modifiche non autorizzate da personale interno o da collaboratori con credenziali legittime: copia di footage, alterazione di configurazioni, manomissione di dataset. L'insider salta le difese perimetrali per definizione, quindi i controlli efficaci sono organizzativi: segregazione dei compiti, revisione degli accessi, tracciabilità.

Riferimenti: Minaccia classica trasversale (accessi legittimi abusati).

Valutazione: probabilità bassa, impatto alto, priorità media. Probabilità bassa: l'organico è contenuto e non ci sono segnali interni, ma la stima è la meno solida del registro perché si basa su assenza di evidenza. Impatto alto: chi è dentro raggiunge footage, modelli e configurazioni di attuazione insieme. Contromisure collegate: C2, I1, I6, A3.

R07 - Supply chain algoritmica e dipendenze

Compromissione a monte: modelli pre-addestrati con backdoor, librerie ML alterate, servizi cloud violati. L'ecosistema ML è particolarmente esposto: pesi scaricati da hub pubblici, formati di serializzazione che eseguono codice, alberi di dipendenze profondi. Una compromissione a questo livello eredita la fiducia di tutta la piattaforma.

Riferimenti: ATLAS: ML Supply Chain Compromise | OWASP ML: Supply Chain Vulnerabilities.

Valutazione: probabilità media, impatto alto, priorità alta. Probabilità media: gli attacchi supply chain sul canale ML sono documentati e in crescita. Impatto alto: il codice o il modello compromesso entra già fidato, opera a monte di ogni controllo interno e si propaga a tutti i clienti della piattaforma. Contromisure collegate: I5, C3, I3.

R08 - Denial of Service su componenti critici

Saturazione dei componenti di inference o della rete di raccolta: DDoS sugli endpoint, esaurimento di risorse con richieste costose, interruzione dei flussi video. Il servizio di monitoraggio si interrompe e la dashboard resta cieca; il punto architetturale decisivo è cosa fanno i semafori quando la piattaforma tace.

Riferimenti: Minaccia classica (DDoS) su endpoint di inference e raccolta.

Valutazione: probabilità media, impatto medio, priorità media. Probabilità media: il DDoS è commodity e gli endpoint sono raggiungibili. Impatto medio, a una condizione organizzativa precisa: la centrale semaforica deve degradare su programmazione locale autonoma (requisito A1). Senza quel fallback l'impatto salirebbe ad alto, perché l'indisponibilità toccherebbe l'attuazione e non solo l'osservazione. Contromisure collegate: A1, A2, A4.

R09 - Inferenze errate e discriminatorie

Correlazioni spurie e bias nei dati che producono inferenze sistematicamente sbagliate su gruppi o aree: più segnalazioni di comportamento a rischio in certi quartieri per squilibri del dataset, tassi di errore diversi per condizioni di illuminazione o densità. Il danno è legale (GDPR e AI Act) e reputazionale prima che tecnico.

Riferimenti: Rischio di bias e correlazioni spurie | AI Act artt. 9-10.

Valutazione: probabilità media, impatto medio, priorità media. Probabilità media: senza una data governance esplicita il bias nei dati urbani è l'esito atteso, non l'eccezione. Impatto medio: contenziosi, rilievi delle autorità e perdita di legittimità pubblica del servizio, con effetto diretto sui contratti con la PA. Contromisure collegate: I2, I6, C4.

R10 - Tracciabilità delle decisioni assente

Incompletezza o assenza di log che ricostruiscano le decisioni del sistema: quale modello ha classificato cosa, con quali input, con quale esito sull'attuazione. Senza tracciabilità ogni contestazione resta indifendibile (un incidente stradale con semaforo adattivo coinvolto), la forensics lavora cieca e l'obbligo di record-keeping dell'AI Act resta scoperto.

Riferimenti: Vulnerabilità di governance | AI Act art. 12 (record-keeping).

Valutazione: probabilità alta, impatto medio, priorità alta. Probabilità alta: è lo stato di fatto dei sistemi non progettati per l'audit; senza intervento la lacuna è certa, non probabile. Impatto medio: non genera eventi avversi da solo, ma amplifica il costo e la durata di tutti gli altri (l'incidente simulato lo mostra sulla finestra di rilevazione). Contromisure collegate: I6.

6. Registro dei rischi

ID	Rischio	Probabilità	Impatto	Priorità	Contromisure
R04	Esfiltrazione di dati personali	Alta	Alto	Critica	C1, C2, C3, C4, I6
R01	Data poisoning del training set	Media	Alto	Alta	I1, I2, I4, I6
R02	Attacchi adversarial in inference	Media	Alto	Alta	I3, I6, A3

ID	Rischio	Probabilità	Impatto	Priorità	Contromisure
R07	Supply chain algoritmica e dipendenze	Media	Alto	Alta	I5, C3, I3
R10	Tracciabilità delle decisioni assente	Alta	Medio	Alta	I6
R03	Furto ed estrazione del modello	Media	Medio	Media	C2, C3, I6
R05	Compromissione della pipeline di labeling	Media	Medio	Media	I2, I4, C3
R06	Insider threat	Bassa	Alto	Media	C2, I1, I6, A3
R08	Denial of Service su componenti critici	Media	Medio	Media	A1, A2, A4
R09	Inferenze errate e discriminatorie	Media	Medio	Media	I2, I6, C4

Tabella 3 - Registro dei rischi, ordinato per priorità.



Figura 3 - Heatmap probabilità x impatto con i dieci rischi posizionati.

Letture critica. Tre osservazioni sulla distribuzione. L'unico rischio critico (R04) è il meno 'AI-native' del registro: vie d'attacco tradizionali contro un asset che l'AI rende solo più ricco e appetibile; la sicurezza classica resta il fondamento anche qui. Il cluster ad alta priorità (R01, R02, R07, R10) riguarda invece integrità e tracciabilità del comportamento del modello: è la parte specificamente AI del problema ed è

quella dove i controlli organizzativi esistenti delle aziende tradizionali coprono meno. Infine R06 mostra il limite della scala: probabilità bassa stimata per assenza di evidenza, non per evidenza di assenza; il registro va riletto se cambiano organico, clima interno o accessi privilegiati.

7. Contromisure ad alto livello (triade CIA)

Come richiesto dalla traccia, le contromisure sono organizzative e di governance: definiscono cosa l'azienda deve presidiare e con quali processi, non come implementarlo tecnicamente. Ogni contromisura ha un identificativo; la matrice in coda al capitolo la aggancia ai rischi che tratta, così ogni controllo esiste perché un rischio lo giustifica e ogni rischio ha almeno un controllo. È la difesa più semplice contro il rischio opposto: la lista di controlli scollegata dal registro, che produce conformità di facciata.

7.1 Confidentiality (riservatezza)

Proteggere footage, metadati e modelli da accessi e divulgazioni non autorizzati.

- **C1 - Classificazione dei dati e minimizzazione.** Policy di classificazione per footage e metadati; pre-analisi edge e offuscamento dove la finalità lo consente; retention breve e motivata.
- **C2 - Least privilege e gestione accessi privilegiati.** Accessi nominali con MFA per ogni canale remoto, revisione periodica dei privilegi, gestione dedicata (PAM) per fornitori e manutenzione, offboarding formalizzato.
- **C3 - Due diligence e contrattualistica di filiera.** Requisiti di sicurezza nei contratti: DPA art. 28 con i responsabili, diritto di audit, obbligo di notifica incidenti del fornitore, verifica periodica della postura dichiarata.
- **C4 - Pseudonimizzazione dei dataset di training.** Regola organizzativa: il training usa dati minimizzati e, dove possibile, resi non riconducibili; il footage integrale non lascia lo storage governato.

7.2 Integrity (integrità)

Garantire che dati, modelli e decisioni non siano alterati, e che ogni evoluzione sia governata e ricostruibile.

- **I1 - Governance del ciclo di vita di dati e modelli.** Versioning e provenance documentati per dataset e modelli, ownership nominata, gestione formale delle modifiche.
- **I2 - Validazione e revisione periodica di dataset e modelli.** Controlli statistici pre-training, campionamento di qualità sulle annotazioni, audit periodico delle modifiche, monitoraggio del comportamento per segmento.
- **I3 - Criteri di rilascio verificabili.** Gate di approvazione prima della produzione: confronto con la versione precedente, esiti dei test di robustezza richiesti come requisito di processo, firma del rilascio.
- **I4 - Controllo del canale di labeling.** Doppia annotazione a campione, accordi di qualità misurabili col vendor, segregazione tra chi annota e chi valida.
- **I5 - Gestione della supply chain algoritmica.** Registro di modelli pre-addestrati, librerie e servizi; valutazione documentata prima dell'adozione; monitoraggio degli avvisi di sicurezza sulle dipendenze.
- **I6 - Tracciabilità delle decisioni e conservazione dei log.** Requisito di record-keeping allineato all'art. 12 AI Act: log di inference, versioni di modello e accessi conservati su orizzonte adeguato a rilevazione, forensics e obblighi normativi.

7.3 Availability (disponibilità)

Mantenere il servizio, e degradarlo in modo sicuro quando il mantenimento fallisce.

- **A1 - Continuità operativa e fallback sicuro.** Requisito architetturale e contrattuale: l'attuazione semaforica degrada su programmazione locale autonoma; piani di continuità documentati e testati.
- **A2 - SLA e ridondanza contrattuale.** Livelli di servizio e ridondanza definiti nei contratti con cloud provider e fornitori critici, con penali e verifiche.
- **A3 - Incident management orientato alla safety.** Processo di gestione incidenti con ruoli, priorità safety esplicita, esercitazioni periodiche (tabletop) e canali di notifica pronti.
- **A4 - Protezione della capacità di servizio.** Misure anti-DoS come requisito verso il provider, soglie di capacità monitorate, piani di assorbimento del carico anomalo.

7.4 Matrice di tracciabilità rischi-contromisure

ID	Contromisura	R01	R02	R03	R04	R05	R06	R07	R08	R09	R10
C1	Classificazione e minimizzazione				X						
C2	Least privilege e PAM			X	X		X				
C3	Due diligence di filiera			X	X	X		X			
C4	Pseudonimizzazione training				X					X	
I1	Ciclo di vita dati e modelli	X					X				
I2	Validazione periodica	X				X				X	
I3	Criteri di rilascio		X					X			
I4	Controllo labeling	X				X					
I5	Supply chain algoritmica							X			
I6	Tracciabilità e log	X	X	X	X		X			X	X
A1	Continuità e fallback								X		
A2	SLA e ridondanza								X		
A3	Incident management		X				X				
A4	Protezione capacità								X		

Tabella 4 - Copertura dei rischi da parte delle contromisure organizzative.

Lettura critica. La matrice rende visibili due squilibri voluti e uno da correggere. Le contromisure di integrità sono le più numerose: coerente con un sistema il cui prodotto è il comportamento del modello. La riga più lunga è I6, com'è inevitabile per un controllo trasversale per natura; al netto di I6, C2 e C3 sono le contromisure a copertura più ampia, conferma che il perimetro accessi-fornitori è il miglior investimento, come anticipato nel capitolo 3. Il punto debole è R10, coperto dalla sola I6: una dipendenza

singola su un rischio ad alta priorità. Non è un caso, la tracciabilità o si progetta o non esiste; ma significa che I6 va trattata come requisito non negoziabile, e infatti la roadmap la colloca nel primo orizzonte.

8. Analisi di conformità normativa

Tre regimi si applicano simultaneamente e guardano il sistema da angoli diversi: il GDPR protegge i dati personali trattati, l'AI Act regola il sistema AI in quanto tale, la NIS 2 chiede resilienza cyber all'organizzazione che lo eroga. La figura 4 riassume ruoli e obblighi; le checklist che seguono valutano lo stato attuale e i gap, con la colonna 'stato' su tre valori: presidiato, parziale, gap.

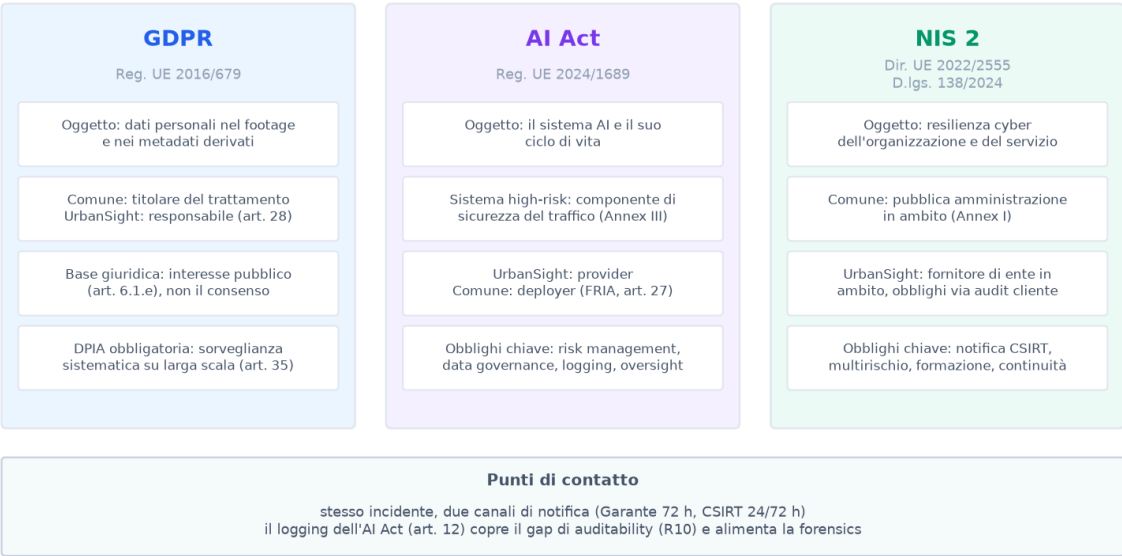


Figura 4 - Il quadro normativo applicabile: oggetto, ruoli e obblighi chiave dei tre regimi, con i punti di contatto.

8.1 GDPR (Reg. UE 2016/679)

Il footage urbano contiene dati personali per definizione: volti, targhe, pattern di spostamento. Il comune, che decide finalità e mezzi del monitoraggio, è titolare del trattamento; UrbanSight opera come responsabile ex art. 28, con cloud provider e vendor di labeling come sub-responsabili da autorizzare e vincolare contrattualmente. La base giuridica ragionevole è l'esecuzione di un compito di interesse pubblico (art. 6.1.e) in capo al comune: il consenso non è praticabile in uno spazio pubblico attraversato da chiunque, e va quindi compensato con trasparenza rafforzata, informativa multilivello e minimizzazione dimostrabile. La sorveglianza sistematica di aree accessibili al pubblico su larga scala rende la DPIA obbligatoria (art. 35), da condurre con il titolare prima dell'estensione del servizio.

Requisito	Stato	Gap e azione
Ruoli e contratti art. 28 (comune, UrbanSight, sub-responsabili)	Parziale	DPA presenti col cloud provider; da formalizzare col vendor di labeling
Base giuridica documentata col titolare	Parziale	Riferimento all'interesse pubblico presente nei contratti; manca l'analisi documentata per finalità
DPIA per il trattamento ad alto rischio	Gap	Non ancora condotta; da avviare congiuntamente col comune (orizzonte 0-3 mesi)

Requisito	Stato	Gap e azione
Minimizzazione e retention del footage	Parziale	Pre-analisi edge attiva su parte dei siti; policy di retention non uniforme tra i comuni
Limitazione della finalità	Parziale	Finalità di monitoraggio documentate; esclusione formale dei riusi non previsti (marketing, indagini) da fissare nei contratti col titolare
Diritti degli interessati (accesso, cancellazione, opposizione)	Gap	Manca la procedura operativa per riscontrare richieste su footage; da definire con il titolare
Informativa e trasparenza (cartellonistica, informativa estesa)	Parziale	Cartellonistica presente; informativa estesa da aggiornare su finalità AI
Registro dei trattamenti e misure art. 32	Parziale	Registro esistente; misure tecniche e organizzative da riallineare a questo documento
Procedura data breach artt. 33-34	Parziale	Processo definito sulla carta, mai esercitato; il capitolo 9 ne simula il funzionamento

Tabella 5 - Checklist GDPR e gap analysis.

8.2 AI Act (Reg. UE 2024/1689)

La classificazione va argomentata in due passi. Primo, cosa UrbanSight non è: il sistema non esegue identificazione biometrica remota né riconoscimento delle emozioni; rileva eventi e comportamenti (attraversamenti pericolosi, incidenti, flussi), non identità. Questo confine è una scelta di design da presidiare esplicitamente, perché separa il sistema dalle pratiche vietate o fortemente limitate dall'art. 5 e da un regime di obblighi ben più gravoso. Secondo, cosa è: un componente di sicurezza nella gestione del traffico stradale, ambito che l'Annex III colloca tra i sistemi high-risk. UrbanSight è provider del sistema; i comuni sono deployer, e in quanto enti pubblici sono tenuti alla valutazione d'impatto sui diritti fondamentali (FRIA, art. 27), che UrbanSight deve mettere in condizione di svolgere. Gli obblighi per i sistemi high-risk dell'Annex III si applicano da agosto 2026: la gap analysis che segue è, di fatto, il piano di lavoro dei prossimi mesi.

Requisito (provider, salvo dove indicato)	Stato	Gap e azione
Verifica di non ricadere nelle pratiche art. 5	Presidiato	Confine di design documentato in questo capitolo; da mantenere nelle evoluzioni di prodotto
Sistema di risk management (art. 9)	Parziale	Questo documento ne è il primo ciclo; va reso processo continuo con revisioni pianificate
Data governance su training e testing (art. 10)	Parziale	Controlli I1-I4 definiti ma non ancora operativi sulla filiera di labeling
Documentazione tecnica (art. 11, Annex IV)	Gap	Da produrre; struttura derivabile dalla mappatura del capitolo 3
Record-keeping e logging (art. 12)	Gap	Coincide con la contromisura I6 e col rischio R10; primo orizzonte della roadmap

Requisito (provider, salvo dove indicato)	Stato	Gap e azione
Trasparenza e istruzioni verso il deployer (art. 13)	Parziale	Documentazione operativa esistente; da integrare con limiti noti e casi d'uso impropri
Sorveglianza umana (art. 14)	Parziale	Operatori presenti sulle decisioni semaforiche; ruoli e autorità di override da formalizzare
Accuratezza, robustezza, cybersecurity (art. 15)	Parziale	Metriche di accuratezza monitorate; robustezza adversarial non testata sistematicamente (roadmap 6-12 mesi)
Sistema di gestione qualità (art. 17)	Gap	Da impostare; conviene integrarlo col percorso ISO della roadmap invece di costruirlo isolato
Valutazione di conformità e registrazione UE (artt. 43, 49)	Gap	Percorso di valutazione per controllo interno e registrazione nella banca dati UE da pianificare prima di agosto 2026
Supporto alla FRIA del deployer pubblico (art. 27)	Gap	Da predisporre un pacchetto informativo standard per i comuni

Tabella 6 - Checklist AI Act e gap analysis.

8.3 NIS 2 (Dir. UE 2022/2555, D.lgs. 138/2024)

L'applicabilità si valuta con un test a due cancelli: settore e dimensione. UrbanSight come azienda privata di software non rientra necessariamente in modo diretto, e la soglia dimensionale (50 dipendenti o 10 milioni di euro) dipende dalla crescita; ma il punto decisivo è un altro. I clienti sono pubbliche amministrazioni, settore incluso nell'ambito della direttiva, e la NIS 2 obbliga gli enti in ambito a verificare i propri fornitori: gli obblighi arrivano quindi per via contrattuale e di audit anche dove la legge non arriva direttamente. Considerare la piattaforma come infrastruttura critica di fatto, indipendentemente dall'esito formale del test, è la postura prudente e quella commercialmente sensata nelle gare pubbliche.

Requisito	Stato	Gap e azione
Determinazione formale dell'ambito (diretto o via fornitura)	Gap	Valutazione legale da completare; nel frattempo si adotta la postura da soggetto in ambito
Notifica incidenti al CSIRT (preallarme 24 h, notifica 72 h, relazione finale)	Parziale	Processo disegnato e simulato nel capitolo 9; mai esercitato in reale, serve un tabletop annuale
Formazione dell'organo di gestione e del personale	Gap	Nessuna formazione strutturata erogata; primo ciclo entro sei mesi
Analisi multirischio (cyber, fisico, ambientale, umano)	Parziale	Questo registro copre il cyber; da estendere a guasti, eventi fisici e ambientali sui siti
Misure di gestione del rischio art. 21 (policy, vulnerabilità, continuità, supply chain, cifratura, MFA)	Parziale	Copertura disomogenea; le contromisure C2, C3, I5, A1-A4 ne sono la declinazione organizzativa
Registro dei fornitori critici con verifica periodica	Parziale	Fornitori censiti; cadenza di verifica e criteri di rischio da formalizzare

Requisito	Stato	Gap e azione
Monitoraggio delle comunicazioni delle autorità	Gap	Nessun presidio nominato; da assegnare come responsabilità esplicita

Tabella 7 - Checklist NIS 2 e gap analysis.

Lettura critica. Tracciabilità e logging servono l'art. 12 AI Act, la forensics NIS 2 e la dimostrabilità GDPR insieme; la gestione dei fornitori serve l'art. 28 GDPR, la supply chain NIS 2 e la data governance AI Act; il processo incidenti serve i due canali di notifica e la continuità. I tre regimi chiedono in gran parte lo stesso impianto con lessici diversi: costruirlo una volta sola, mappandolo sui tre, è la differenza tra governance e burocrazia triplicata.

9. Incident report simulato (INC-2026-004)

Natura del documento

Esercitazione su scenario interamente fittizio: organizzazioni, date e numeri sono simulati per mettere alla prova processi, tempi di notifica e comunicazioni descritti nei capitoli precedenti. Lo scenario scelto (compromissione di un accesso di terza parte) corrisponde al rischio a priorità più alta del registro, R04, e attiva entrambi i canali di notifica normativi: è il caso che esercita più processo per unità di scenario.

9.1 Sintesi per la direzione

Un accesso di manutenzione remota, legittimo ma protetto in modo insufficiente, è stato usato da attaccanti esterni per copiare registrazioni video e componenti del sistema di analisi. L'anomalia è stata individuata osservando un volume di traffico in uscita incoerente con l'operatività normale. Non risultano alterazioni dei dati o del comportamento del sistema: il servizio non si è mai interrotto e l'integrità dei modelli in esercizio è stata verificata. Il danno riguarda la riservatezza: registrazioni di spazi pubblici riferibili a persone, trattate per conto del comune, sono uscite dal perimetro aziendale. Le autorità competenti e il comune titolare sono stati informati nei termini di legge.

9.2 Classificazione e portata

Campo	Valore
Identificativo	INC-2026-004 (simulato)
Tipologia	Violazione di riservatezza; sospetto furto di proprietà intellettuale
Vettore iniziale	Phishing su un tecnico del fornitore di manutenzione; credenziali VPN riutilizzate
Asset coinvolti	Storage footage (circa 72 ore di registrazioni da 40 telecamere, circa 2.1 TB); model registry (copia dei pesi del detector pedoni v2.3.1)
Rischi di registro attivati	R04 (esfiltrazione di dati personali) e R03 (furto del modello); il vettore, credenziali legittime di terza parte compromesse, è il perimetro presidiato dalle contromisure C2 e C3
Impatto CIA	Riservatezza: violata. Integrità: verificata, nessuna alterazione. Disponibilità: servizio mai interrotto

9.3 Cronologia

Incidente INC-2026-004: linea temporale

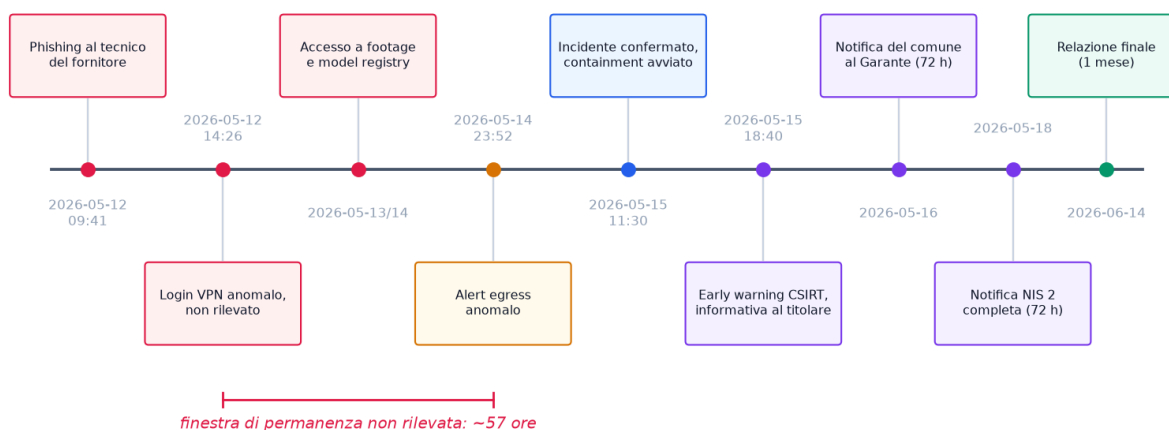


Figura 5 - Linea temporale dell'incidente simulato: compromissione, rilevazione, contenimento e catena delle notifiche.

Il phishing del 12 maggio ottiene le credenziali VPN del tecnico del fornitore; il primo accesso anomalo avviene poche ore dopo da infrastruttura estranea e non genera allarmi, perché l'accesso è formalmente valido e privo di MFA. Nelle 57 ore successive l'attaccante esplora il segmento raggiungibile dalla VPN di manutenzione, che consente di arrivare sia allo storage del footage sia al model registry, e avvia la copia. È il volume dell'egress notturno del 14 maggio a superare le soglie e generare l'alert; il triage del mattino seguente conferma l'incidente alle 11:30 e fa scattare il contenimento: revoca delle credenziali del fornitore, blocco delle rotte VPN, rotazione dei segreti raggiungibili, acquisizione forense delle evidenze con hash, isolamento del segmento. Le notifiche partono la sera stessa.

9.4 Notifiche e comunicazioni

Destinatario	Base normativa	Termine	Esito nella simulazione
Comune (titolare del trattamento)	GDPR art. 33.2 (responsabile verso titolare)	Senza ingiustificato ritardo	Informato il 15 maggio in serata, con scheda tecnica
CSIRT Italia	NIS 2 / D.lgs. 138/2024	Preallarme entro 24 h dalla conoscenza	Inviato il 15 maggio alle 18:40 (conoscenza: 11:30)
Garante privacy	GDPR art. 33 (adempimento del titolare)	72 h dalla conoscenza	Notifica del comune il 16 maggio, supportata da UrbanSight
CSIRT Italia (aggiornamento)	NIS 2	Notifica completa entro 72 h	Inviata il 18 maggio con indicatori e stato del contenimento
Interessati	GDPR art. 34, se rischio elevato	Valutazione col titolare	Comunicazione individuale impraticabile; informazione

Destinatario	Base normativa	Termine	Esito nella simulazione
			pubblica su canali del comune
Assicurazione e clienti	Obblighi contrattuali	Da contratto	Informati il 16-17 maggio con nota dedicata
CSIRT Italia (relazione finale)	NIS 2	Entro 1 mese	Trasmessa il 14 giugno con causa radice e piano di rimedio

Tabella 9 - Catena delle notifiche nella simulazione.

9.5 Causa radice e lezioni

La ricostruzione segue il metodo forense in quattro fasi visto nel modulo: identificazione delle sorgenti di evidenza (log VPN, log dello storage, registry), acquisizione con copie conformi e hash, analisi, presentazione. La conclusione non è un'ipotesi: è basata sulle evidenze acquisite ed è ripetibile. La causa radice non è il singolo tecnico caduto nel phishing ma l'assenza di controlli strutturati sul canale di terza parte: niente MFA sull'accesso VPN di manutenzione, segmentazione che permetteva a quell'accesso di raggiungere asset non pertinenti alla manutenzione, logging del registry incompleto, che ha allungato l'accertamento di cosa fosse stato copiato.

- **Lezione 1.** MFA e gestione dedicata degli accessi privilegiati di terze parti (contromisura C2) non sono un miglioramento: sono il controllo la cui assenza ha reso possibile l'incidente.
- **Lezione 2.** La finestra di permanenza di 57 ore è il costo misurabile del gap di tracciabilità (R10, contromisura I6): con log completi sugli accessi al registry l'anomalia era rilevabile al primo accesso, non al picco di egress.
- **Lezione 3.** Le notifiche hanno retto i termini perché nella simulazione ruoli e modelli di comunicazione erano pronti; la gap analysis NIS 2 dice che oggi non lo sono. Il tabletop annuale trasforma questa differenza in capacità reale.

Lettura critica. La simulazione conferma la lettura del registro: l'incidente più verosimile non attacca il modello, attacca il perimetro organizzativo intorno al modello. Ed espone una dipendenza incrociata utile da nominare: la qualità della risposta GDPR e NIS 2 dipende da capacità tecniche (logging, forensics) che nei capitoli precedenti risultano tra i gap, quindi i termini di notifica rispettati qui sono un esito ottimistico, non atteso, finché la roadmap non chiude I6 e A3.

10. Raccomandazioni organizzative e roadmap

Le raccomandazioni sono di processo e governance, coerenti con l'ambito del documento. Cinque linee: istituire un presidio di sicurezza AI con ownership nominata (un comitato leggero che possiede registro dei rischi, roadmap e revisioni, non una nuova struttura); trattare il perimetro accessi-fornitori come priorità assoluta di controllo; rendere la tracciabilità delle decisioni un requisito di prodotto non negoziabile; portare la conformità dentro il ciclo di sviluppo invece di appaltarla a valle; esercitare i processi di incidente prima che servano. La tabella traduce le linee in attività su tre orizzonti.

Orizzonte	Attività	Aggancio
0-3 mesi	MFA su tutti gli accessi remoti e gestione dedicata delle utenze di terze parti; avvio DPIA congiunta col comune capofila; procedura di notifica multi-regime con un tabletop; adozione del registro rischi come documento vivo con revisione trimestrale	C2, C3, A3; GDPR art. 35; lezioni 1 e 3 dell'incidente
3-6 mesi	Estensione del registro ad analisi multirischio NIS 2 (eventi fisici e ambientali); primo ciclo di formazione per organo di gestione e personale; audit del vendor di labeling; piano di logging e tracciabilità delle decisioni con requisiti art. 12	NIS 2 art. 21; I4, I6; AI Act artt. 10-12
6-12 mesi	Documentazione tecnica AI Act completa e pacchetto FRIA per i deployer; programma periodico di test di robustezza adversarial; valutazione di un percorso di certificazione (ISO/IEC 27001, prospetticamente 42001); audit indipendente dell'impianto e revisione annuale del registro	AI Act artt. 11, 15, 27; consolidamento dell'intero impianto

Tabella 10 - Roadmap delle attività successive.

11. Limiti dell'analisi e follow-up

Tre limiti vanno dichiarati. L'analisi è qualitativa: ordina i rischi ma non quantifica perdite attese, e alcune stime (R06 su tutte) poggiano su assenza di evidenza. È teorica: nessuna contromisura è stata verificata sul campo e nessun test tecnico è stato eseguito, per scelta di ambito; la robustezza reale del perimetro resta non misurata. È un'istantanea: la valutazione di conformità è ad alto livello e non sostituisce il parere legale, e il quadro normativo stesso è in evoluzione. I follow-up naturali sono la DPIA congiunta, il tabletop sull'incident response e, a valle della roadmap, un audit tecnico che sottoponga a verifica empirica ciò che qui è stato valutato a tavolino: nell'ordine, prima i processi, poi la carta che li descrive.

Appendice A - Template del registro dei rischi

Struttura riusabile del registro adottato nel capitolo 6, con una riga di esempio. Le checklist di conformità del capitolo 8 sono esse stesse template riusabili: la colonna 'stato' si aggiorna a ogni revisione.

Campo	Contenuto atteso	Esempio
ID	Identificativo stabile del rischio	R04
Rischio	Nome breve e descrizione del vettore	Esfiltrazione di dati personali dal footage
Probabilità	Bassa / media / alta, con motivazione	Alta: superficie ampia, asset appetibile
Impatto	Basso / medio / alto, con motivazione	Alto: violazione su larga scala, sanzioni
Priorità	Da matrice probabilità x impatto	Critica
Contromisure	ID dei controlli collegati	C1, C2, C3, C4, I6
Owner e revisione	Responsabile e data ultima revisione	Presidio sicurezza AI, 2026-07

Tabella A.1 - Template del registro dei rischi.

Appendice B - Modello di incident report

Campi del modello standardizzato, compilato nel capitolo 9 sullo scenario simulato.

- **Identificazione.** ID incidente, data e ora di rilevazione e di conferma, classificazione, sistemi e dati coinvolti.
- **Sintesi per la direzione.** Cosa è successo, in linguaggio accessibile a lettori non tecnici; cosa è compromesso e cosa no.
- **Cronologia.** Sequenza degli eventi con orari: compromissione, rilevazione, conferma, contenimento, eradicazione, ripristino.
- **Impatti.** Effetti su riservatezza, integrità e disponibilità; impatti legali, contrattuali e reputazionali.
- **Notifiche.** Destinatari, basi normative, termini e stato di ciascuna comunicazione (titolare, CSIRT, Garante, interessati, clienti, assicurazione).
- **Evidenze.** Sorgenti acquisite, hash delle copie, catena di custodia; la ricostruzione deve essere ripetibile.
- **Causa radice e lezioni.** Analisi orientata al processo, non al colpevole; azioni correttive con owner e scadenza.